

Denali Health — CMS Blue Button Production Access Demo

Quick Reference Q&A

Prepared April 13, 2026

1. Data Storage & Privacy

Q: What data do you store from the Blue Button API? We never store raw FHIR bundles. We fetch claims data, extract only what's needed (conditions, medications, screenings, coverage status), and cache the transformed summaries. We store age and gender from the Patient resource — never names, DOB, addresses, or Medicare Beneficiary IDs. Cached data is encrypted at rest via RDS AES-256 and deleted on disconnect.

Q: How long do you retain Medicare data? Cached health data refreshes every 24 hours and is permanently deleted when the user disconnects Medicare or deletes their account. Audit logs are retained for 6 years per HIPAA with the `user_id` nulled after account deletion — we know an action happened but can't tie it to a person.

Q: Do you share Medicare data with third parties? Medicare health data is sent to Anthropic's Claude AI (via AWS Bedrock) only when the user explicitly enables the "Use health data in AI conversations" toggle. This toggle is OFF by default. No other third parties receive Medicare data. Our vendors (AWS, Stripe) have BAAs.

Q: What happens when a user disconnects Medicare? All cached health data, health reports, and diabetes insights are immediately and permanently deleted. The user sees a confirmation dialog before disconnecting. After disconnect, the health page returns to the "Connect Your Medicare" empty state.

Q: What happens when a user deletes their account? All user data is permanently deleted in a single database transaction (all-or-nothing). This includes conversations, messages, appeals, health data, subscriptions, and consent preferences. Audit logs survive with `user_id` set to NULL per HIPAA 6-year retention. The Cognito identity is also deleted.

2. AI & Consent

Q: How does the AI use Medicare data? The AI only sees Medicare data if the user explicitly enables the "Use health data in AI conversations" toggle in Settings. When enabled, the AI receives transformed summaries — conditions, medications (detailed for diabetes/obesity, count-only for others), coverage status, and recent claims. Raw FHIR data is never sent.

Q: What model powers the AI? Claude Sonnet 4.6 via AWS Bedrock for general coverage questions. Claude Opus 4.6 for appeal letter generation, which requires more sophisticated reasoning across medical codes, coverage policies, and clinical evidence.

Q: Is AI output clearly labeled? Yes. Every AI response shows "AI-generated · May contain errors · Not medical advice" at the bottom. Appeal letters include a prominent disclaimer: "This is a DRAFT letter generated by AI. It is NOT legal advice." The CMS Health AI Pledge link appears on every chat page.

Q: What consent gates exist? Three toggles in Settings, all OFF by default: (1) Use health data in AI conversations, (2) Store health data locally, (3) Usage analytics. Each has a plain-English description. The AI

toggle specifically discloses that data goes to "Anthropic's Claude AI."

3. Security & Compliance

Q: How is data encrypted? In transit: TLS 1.2+ for all connections. At rest: RDS AES-256 encryption (AWS KMS). OAuth tokens have additional app-layer AES-256-GCM encryption. The database is private (no public endpoint), accessible only from the ECS container within the VPC.

Q: Do you have a BAA with AWS? Yes, signed February 25, 2026. Covers RDS (database), ECS/Fargate (hosting), Bedrock (AI), and SES (email).

Q: How do you handle PHI in logs? We never log PHI to CloudWatch. AI prompt content, response content, and appeal letter text are never logged — only metadata (content length, tools used, appeal ID). Error logs are sanitized to log err.message only, preventing SQL with PHI from reaching logs.

Q: What audit trail exists? Every significant action is logged to an append-only audit_logs table: login, logout, FHIR data access, appeal generation, appeal outcomes, account deletion. The table has REVOKE UPDATE/DELETE/TRUNCATE applied at the database level — even admin users cannot modify audit records.

Q: How do you handle sessions? 30-minute HIPAA inactivity timeout with on-screen warning. HttpOnly, Secure, SameSite cookies. OTP-based authentication via AWS Cognito and SES. No password storage.

4. Appeal Letters

Q: How does the appeal letter feature work? The user describes their denial in plain English. The AI identifies the denial type, looks up ICD-10 and CPT codes, searches Medicare coverage policies (LCDs/NCDs), pulls clinical evidence from PubMed, and generates a formal appeal letter. The letter uses blank lines for sensitive fields (Medicare number, claim number, date of service) that the user fills in by hand.

Q: Does the appeal letter contain PHI? The letter contains the diagnosis, procedure, and denial reason (user-provided), plus ICD-10/CPT codes and coverage policy references (public data). It does NOT contain the Medicare Beneficiary ID, full name, DOB, address, or dollar amounts. Sensitive fields use blank lines.

Q: What appeal levels do you support? Level 1 (Redetermination/Organization Determination), Level 2 (QIC/IRE Reconsideration), and Level 3 (ALJ Hearing) with full letter generation. Levels 4-5 show guidance only — these require legal representation. The system handles both Original Medicare and Medicare Advantage with different letter formats, deadlines, and legal citations.

5. CMS-Specific Requirements

Q: Where does the CMS attribution notice appear? In 9 locations: Terms of Service §14, site footer (every page), Connect Medicare page, CMS Pledge component, health report view, health page, appeal letter modal (2 locations), and appeal PDF page 2. All use the exact verbatim text.

Q: Do you use "Blue Button" in any user-facing text? Only in the CMS-mandated attribution notice. All other references use "Medicare" — "Connect Medicare," "Medicare data," "Medicare account." We removed "Blue Button" from the email footer, PDF footer, and AI system prompts.

Q: How do users agree to your Terms and Privacy Policy? During signup, the text reads "By signing in, you agree to our Terms of Service and Privacy Policy" with clickable links to both documents. The user must

enter their email and verify a 6-digit OTP — a two-step affirmative action that's stronger than a checkbox click.

Q: Can enrollees review your privacy policy before signing up? Yes. The Terms and Privacy Policy links are visible and clickable before the user enters any information. Both documents are also linked in the site footer on every page.

Q: What is your readability score? We used readability checking software (textstat/Flesch-Kincaid). Prose sections score grade 9-13 after our simplification pass. The aggregate score is higher (15.4) due to bullet-list formatting that inflates the tool's calculation, but the actual prose is accessible to a Medicare audience.

Q: What is your pricing model? Free Trial (\$0, 14 days, 10 msgs/day, 1 day/week, no appeals). Starter (\$10/month, 1 appeal credit). Plus (\$20/month, 2 appeal credits, daily access). Unlimited (\$60/month). No credit card required for trial. Pricing is transparent on the landing page and consistent across Terms, Privacy Policy, and the app.

Q: Is payment processing live? Stripe is integrated in test mode — the full subscription flow works (plan selection, upgrade, downgrade, cancellation) but no real charges are processed. We will switch to Stripe production mode after receiving CMS production access approval. Stripe is PCI DSS certified and does not store card details on our servers.